

Gate /auth/* vs harness /api/auth/* -- curl

Both surfaces share AuthManager when auth.enabled is the literal boolean true. While it is false, routes still exist and return 503 (not 404). Placeholders only: never put a live password or token in this PDF. SHA 57e052ed9222d42a20b95ceb4dec71d21e169f57.

Cookies are different. CSRF header is the same. Mixing jars 401s.

	Gate (terminal :8787)	Harness (coding :8790)
Prefix	http://127.0.0.1:8787	http://127.0.0.1:8790
Cookie	cyclaw_session	cyclaw_harness_session
CSRF header	X-CyClaw-CSRF	X-CyClaw-CSRF (x-cyclaw-csrf)
Same-origin	enforced on mutating /auth/*	enforced on mutating /api/auth/*
Ops CYCLAW_API_KEY	Not these routes	Not these routes

Route map

Gate	Harness	Notes
GET /auth/setup-status	GET /api/auth/setup-status	No CSRF. {needs_password, username}.
POST /auth/bootstrap-password	POST /api/auth/bootstrap-password	Loopback only. JSON {password}.
POST /auth/login	POST /api/auth/login	JSON {username, password}. Sets cookie, returns csrf_token.
POST /auth/logout	POST /api/auth/logout	CSRF + cookie.
GET /auth/whoami	GET /api/auth/whoami	username + role.
GET /auth/users	GET /api/auth/users	Admin/operator (gate: role check).
POST /auth/users	POST /api/auth/users	JSON {username, password, role?}.
POST /auth/password	POST /api/auth/users/{user}/password	Path differs. JSON {password}.
POST /auth/users/{user}/role	POST /api/auth/users/{user}/role	JSON {role}.
DELETE /auth/users/{user}	DELETE /api/auth/users/{user}	Last admin is 409 AUTH_LAST_ADMIN.
GET /auth/audit/summary	(none)	Session admin/audit. Ops-key twin is GET /audit/summary.

curl -- gate (cookie jar gate.txt)

```
BASE=http://127.0.0.1:8787
JAR=gate.txt

curl -sS $BASE/auth/setup-status
# 503 if auth.enabled is false

# first password -- must be loopback, min 12 chars
curl -sS -c $JAR -b $JAR -H 'Content-Type: application/json' \
  -d '{"password":"PASSWORD_MIN_12"}' \
  $BASE/auth/bootstrap-password
# save csrf_token from JSON

curl -sS -c $JAR -b $JAR -H 'Content-Type: application/json' \
  -d '{"username":"admin","password":"PASSWORD_MIN_12"}' \
  $BASE/auth/login

CSRF=paste_from_login_json
curl -sS -b $JAR -H "X-Cyclaw-CSRF: $CSRF" $BASE/auth/whoami

curl -sS -b $JAR -H "X-Cyclaw-CSRF: $CSRF" $BASE/auth/users
curl -sS -b $JAR -H "X-Cyclaw-CSRF: $CSRF" $BASE/auth/audit/summary

curl -sS -c $JAR -b $JAR -X POST -H "X-Cyclaw-CSRF: $CSRF" \
  $BASE/auth/logout
```

curl -- harness (cookie jar harness.txt)

```
BASE=http://127.0.0.1:8790
JAR=harness.txt

curl -sS $BASE/api/auth/setup-status

curl -sS -c $JAR -b $JAR -H 'Content-Type: application/json' \
  -d '{"password":"PASSWORD_MIN_12"}' \
  $BASE/api/auth/bootstrap-password

curl -sS -c $JAR -b $JAR -H 'Content-Type: application/json' \
  -d '{"username":"admin","password":"PASSWORD_MIN_12"}' \
  $BASE/api/auth/login

CSRF=paste_from_login_json
curl -sS -b $JAR -H "X-Cyclaw-CSRF: $CSRF" $BASE/api/auth/whoami

# self-service password on harness uses the username in the path
curl -sS -b $JAR -H "X-Cyclaw-CSRF: $CSRF" \
  -H 'Content-Type: application/json' \
  -d '{"password":"NEW_PASSWORD_MIN_12"}' \
  $BASE/api/auth/users/admin/password
```

Do not reuse gate.txt against :8790. Device tokens from cyclaw-user token create are Authorization: Bearer on POST /query when auth is on -- still not CYCLAW_API_KEY, and still not a substitute for the session cookie on /auth/.*

Verified from gate_auth.py and harness/server.py. Not verified: live curl against a running pair of servers on this host.